TD de Cryptographie

Simon Abelard

Novembre 2026

Exercice 1 Considérons la fonction suivante écrite en code C.

```
bool verify_pin(const char *input, const char *secret) {
for (int i = 0; i < 4; i++) {
    if (input[i] != secret[i]) {
        return false; // Sortie dès qu'un caractère est faux
    }
}
return true;
}
```

1) Expliquez ce qu'elle fait.

2) En supposant que `input` est uniquement constitué de chiffres de 0 à 9, quel est le nombre maximal de tentatives pour obtenir `true` avec certitude ?

3) En utilisant vos connaissances sur les attaques par canaux auxiliaires, expliquez comment obtenir le même résultat en au plus 40 tentatives.

4) En vous inspirant du cours, proposez plusieurs contre-mesures pour rendre une telle attaque impossible. Discutez leur coût et choisissez la meilleure.

Exercice 2 Soit un schéma PKE défini par les algorithmes (Gen, Chiff, Dechiff). Le mécanisme KEM obtenu via la transformée de Fujisaki-Okamoto (FO) est défini de la manière suivante :

- **Encapsulation(pk) :**
  1. Choisir une graine aléatoire m.
  2. Dériver le pseudo-aléa $r = G(m)$, où G est une fonction de hachage.
  3. Calculer le texte chiffré : $c = \text{Chiff}(pk, m, r)$.
  4. Dériver la clé de session partagée : $K = H(m, c)$, où H est une fonction de hachage.
- **Décapsulation(sk, c) :**
  1. Calculer le message candidat : $m' = \text{Dechiff}(sk, c)$.
  2. **Étape de vérification FO (Ré-encapsulation) :**
     Calculer $r' = G(m')$ puis vérifier si $c == \text{Chiff}(pk, m'; r')$.

3. Si l'égalité est vraie, retourner $K = H(m', c)$. Sinon, rejeter l'opération (ou retourner une valeur pseudo-aléatoire).

1) Expliquez précisément en quoi l'étape de vérification par ré-encapsulation ($c == \text{Chiff}(pk, m', r')$) empêche un attaquant actif de manipuler les bits d'un texte chiffré intercepté pour glaner des informations. Quelle notion de sécurité vu en cours est ainsi garantie ?

La transformée FO et les erreurs de déchiffrement.
Contrairement aux schémas traditionnels (RSA, ECC), les primitives basées sur les réseaux ou les codes ont une probabilité $\delta > 0$ d'échec de déchiffrement.

Un attaquant intercepte un texte chiffré valide c. Il y injecte un petit vecteur d'erreur e_{adv} pour construire un texte chiffré altéré $c' = c + e_{\text{adv}}$, qu'il envoie à la cible pour décapsulation.

2) Que se passe-t-il lors de la vérification FO si cette erreur provoque un échec de déchiffrement induit ($\text{Dechiff}(sk, c') \neq m$) ?

3) Si l'implémentation logicielle renvoie un signal (code d'erreur, message réseau ou variation de temps de calcul) permettant à l'attaquant de savoir si la vérification FO a échoué à cause d'une erreur de déchiffrement, décrivez quels éléments secret l'attaquant peut récupérer et comment il peut procéder.

4) En pratique, les schémas post-quantiques sont conçus pour que la probabilité d'un échec de déchiffrement soit négligeable (i.e. $< 2^{-128}$). Cependant, l'attaquant dispose d'un accès physique au composant et peut provoquer un *glitch*. La faute force le saut conditionnel de la vérification FO à être toujours validé. Expliquez quel pourrait être l'impact sur la sécurité du système post-quantique.

Exercice 3 Soit un bloc de clé privée d'un cryptosystème basé sur les codes QC-MDPC, représenté par un polynôme binaire circulant $h(X)$ de degré $r = 13$, appartenant à l'anneau $\mathbb{F}_2[X]/(X^{13} - 1)$. Le polynôme $h(X)$ possède un poids de Hamming fixe $w = 4$ (exactement 4 coefficients valent 1).

La clé privée peut être caractérisée par son **support**, c'est-à-dire l'ensemble des indices de ses coefficients non nuls :

$$\mathcal{S}_h = \{i \in \{0, \ldots, 12\} \mid h_i = 1\} \quad \text{avec} \quad |\mathcal{S}_h| = 4$$

Le **spectre de distances circulaires** de la clé privée est défini par l'ensemble des écarts minimaux entre toutes les paires d'indices du support :

$$\mathcal{D}(h) = \{\min(|i - j|, r - |i - j|) \mid i, j \in \mathcal{S}_h, i \neq j\}$$

On suppose qu'un attaquant actif est capable de mesurer via un canal auxiliaire le poids de Hamming du syndrome calculé : $HW(S(X))$. L'attaquant injecte un vecteur d'erreur composé de deux bits à 1 espacés d'une distance d :

$$e(X) = 1 + X^d \quad \text{avec} \quad 1 \leq d \leq \lfloor r/2 \rfloor$$

1) Exprimez le syndrome $S(X) = e(X) \cdot h(X) \pmod{X^{13} - 1}$ sous forme polynomiale en fonction de $h(X)$.

2) Que vaut $HW(S)$ si la distance d n'appartient **pas** au spectre de distances $\mathcal{D}(h)$?

3) On suppose que la distance choisie d appartient au spectre de la clé privée ($\exists i, j \in \mathcal{S}_h$ tels que la distance circulaire entre i et j vaut d). Expliquez pourquoi le poids de Hamming du syndrome, $HW(S)$, subit une baisse et devient strictement inférieur à $2 \times w = 8$.

4) En faisant varier l'écart d de 1 à 6, l'attaquant observe les poids de Hamming du syndrome suivants lors des calculs de la victime :

- Pour $d = 1 \implies HW(S) = 4$
- Pour $d = 2 \implies HW(S) = 8$
- Pour $d = 3 \implies HW(S) = 6$
- Pour $d = 4 \implies HW(S) = 4$
- Pour $d = 5 \implies HW(S) = 6$
- Pour $d = 6 \implies HW(S) = 8$

Déduisez-en l'ensemble exact des distances circulaires $\mathcal{D}(h)$ qui composent la clé privée.

5) La structure du code étant quasi-cyclique, le polynôme $h(X)$ est défini à une permutation cyclique près. On peut donc fixer arbitrairement le premier élément du support à 0, soit $\mathcal{S}_h = \{0, ?, ?, ?\}$. En exploitant le spectre $\mathcal{D}(h)$ obtenu à la question précédente, déterminez le support de la clé privée et donnez un polynôme secret $h(X)$ qui possède ce support.

6) Expliquez pourquoi le polynôme h obtenu ci-dessus n'est pas unique. Est-ce un problème pour l'attaquant ?

Exercice 4 On considère un schéma de chiffrement inspiré du problème LWE (schéma de Regev) où la clé privée est un vecteur secret à deux dimensions $\mathbf{s} = (s_1, s_2) \in \mathbb{Z}_q^2$ défini sur l'anneau des entiers modulo $q = 17$ (soit $\mathbb{Z}_{17} = \{0, 1, \ldots, 16\}$).

Lors du déchiffrement d'un texte chiffré $\mathbf{c} = (\mathbf{u}, v) \in \mathbb{Z}_{17}^2 \times \mathbb{Z}_{17}$, l'algorithme commence par calculer la valeur intermédiaire suivante avant d'appliquer une fonction d'arrondi :

$$d = v - \langle \mathbf{u}, \mathbf{s} \rangle \pmod{q} \tag{1}$$

Où $\langle \mathbf{u}, \mathbf{s} \rangle = u_1 s_1 + u_2 s_2 \pmod{q}$ représente le produit scalaire standard.

1) L'attaquant choisit d'envoyer le vecteur unitaire ciblé $\mathbf{u} = (1, 0)$ et fait varier la valeur scalaire de v de 0 à 16.

a. Exprimez la valeur intermédiaire d en fonction de s_1.

b. L'attaquant observe sur l'oscilloscope que pour toutes les valeurs de $v \leq 4$, la puce affiche un comportement A, mais dès que v atteint 5, la consommation bascule sur un comportement B. Déduisez-en la valeur exacte de s_1.

2) L'attaquant souhaite maintenant déterminer le second coefficient s_2.

a. Quel vecteur $\mathbf{u}$ l'attaquant doit-il choisir pour isoler s_2 ?

b. En utilisant ce vecteur, l'attaquant constate que le point de bascule se produit lorsque la valeur de v passe à 11. Calculez la valeur de s_2.

3) Pourquoi cette catégorie d'attaque sur les réseaux euclidiens est-elle qualifiée d'attaque "géométrique" ? **Astuce :** quel type d'objet l'équation $d = v - \langle \mathbf{u}, \mathbf{s} \rangle$ définit-elle ?

4) Citez et expliquez brièvement deux contre-mesures permettant de se prémunir de cette fuite.